

Manual 10 - NIST RMF and SP 800-53 Controlled Implementation

CONTROLLED PUBLICATION QA CANDIDATE

Controlled source revision: 9c420201ad6822c594e74c7f7508e00b53472f4c | Language: en | RMF authorization and human decision boundaries retained.

Assurance boundary: This manual operationalizes NIST RMF and SP 800-53 concepts but does not authorize a system, create NIST certification, prove control effectiveness, establish legal compliance, or replace an accountable authorizing official or competent assessor. Tailoring, assessment, authorization, exceptions, residual risk, and material decisions require accountable human judgment.

Implementation paths

Manual 10 — Implementation Paths

Essential

Use for smaller or bounded systems. Minimum implementation expectations:

- defined system boundary, owner, mission/business context, and accountable roles;
- RMF step ownership and documented decision points;
- appropriate categorization and initial control baseline selection;
- documented tailoring rationale;
- clear identification of common, system-specific, and hybrid controls;
- implementation evidence for selected controls;
- risk-based assessment planning and findings tracking;
- explicit authorization decision by the accountable human official;
- continuous-monitoring cadence, exceptions, and POA&M tracking.

Structured

Use for multiple systems, shared services, regulated environments, or material organizational risk. Add:

- organization-level risk strategy linked to system-level decisions;
- reusable common-control governance and inheritance evidence;
- system security, privacy, and C-SCRM planning aligned to SP 800-18 Rev. 2;
- formal control-tailoring records and overlays where appropriate;
- structured assessment evidence aligned to SP 800-53A;
- machine-readable evidence and OSCAL where operationally useful;
- formal authorization package management;
- recurring continuous-monitoring and reassessment triggers;
- exception, risk-acceptance, and POA&M governance with expiration and remediation ownership.

Enhanced

Use for high-impact, mission-critical, enterprise-scale, highly regulated, or interconnected environments. Add:

- cross-system risk aggregation and enterprise risk reporting;
- rigorous common-control provider governance and inheritance validation;
- independent assessment and specialized technical testing where risk warrants;
- automated evidence collection with provenance controls;
- OSCAL-backed system/control/assessment artifacts where feasible;
- continuous-control monitoring linked to material change and authorization status;
- formal ongoing-authorization criteria where adopted by the organization;
- executive risk acceptance for material residual risk;
- resilience, supply-chain, privacy, and dependency risk integrated into authorization decisions.

RMF evidence route

Manual 10 memory graphic 1

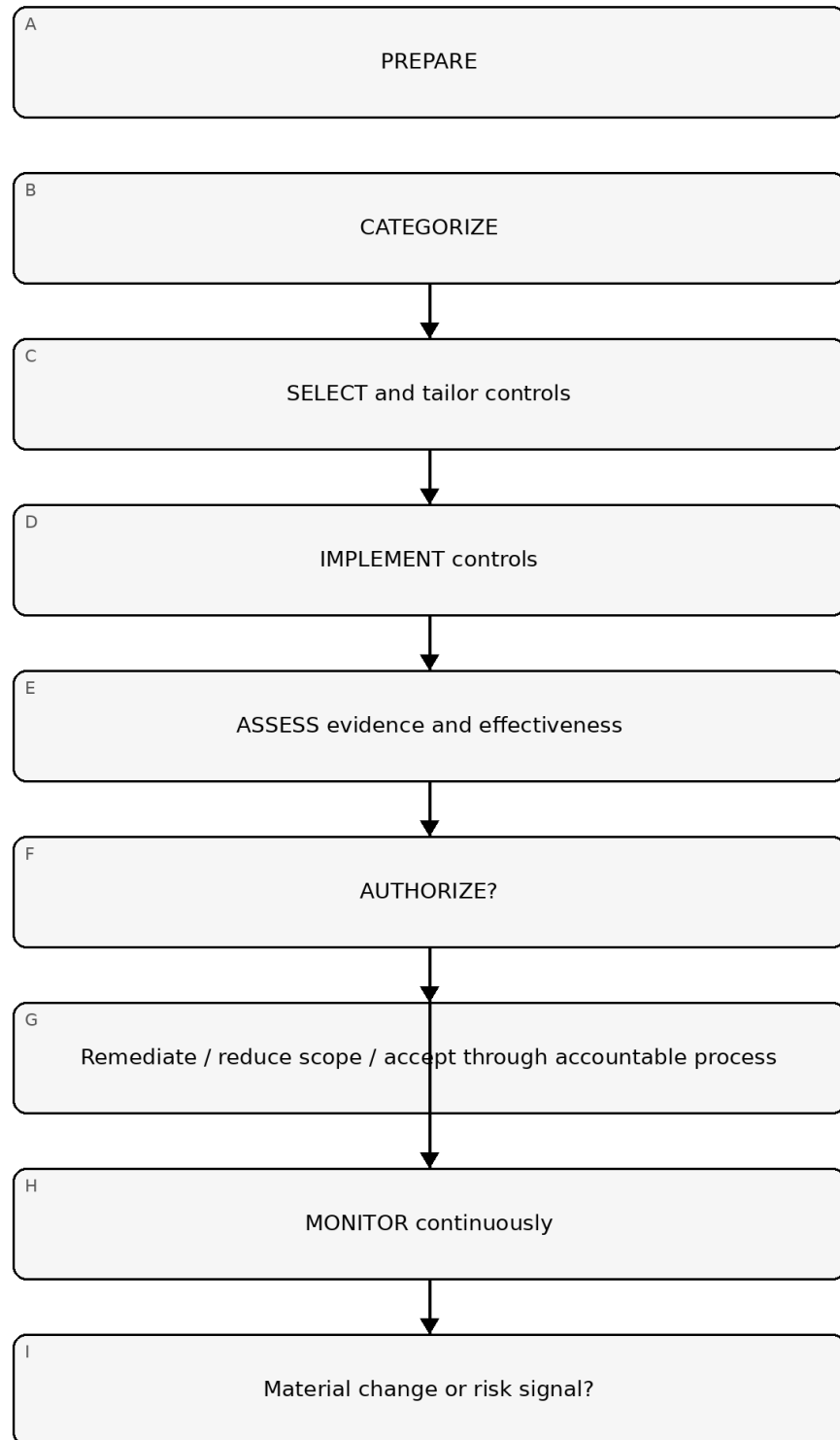


Figure 1. RMF implementation memory graphic

Accessible explanation: RMF is a continuous evidence-and-decision lifecycle. A failed authorization decision returns work for remediation or accountable risk treatment rather than creating automatic approval. Monitoring feeds material change back into preparation and reassessment.

Control evidence chain

Manual 10 memory graphic 2

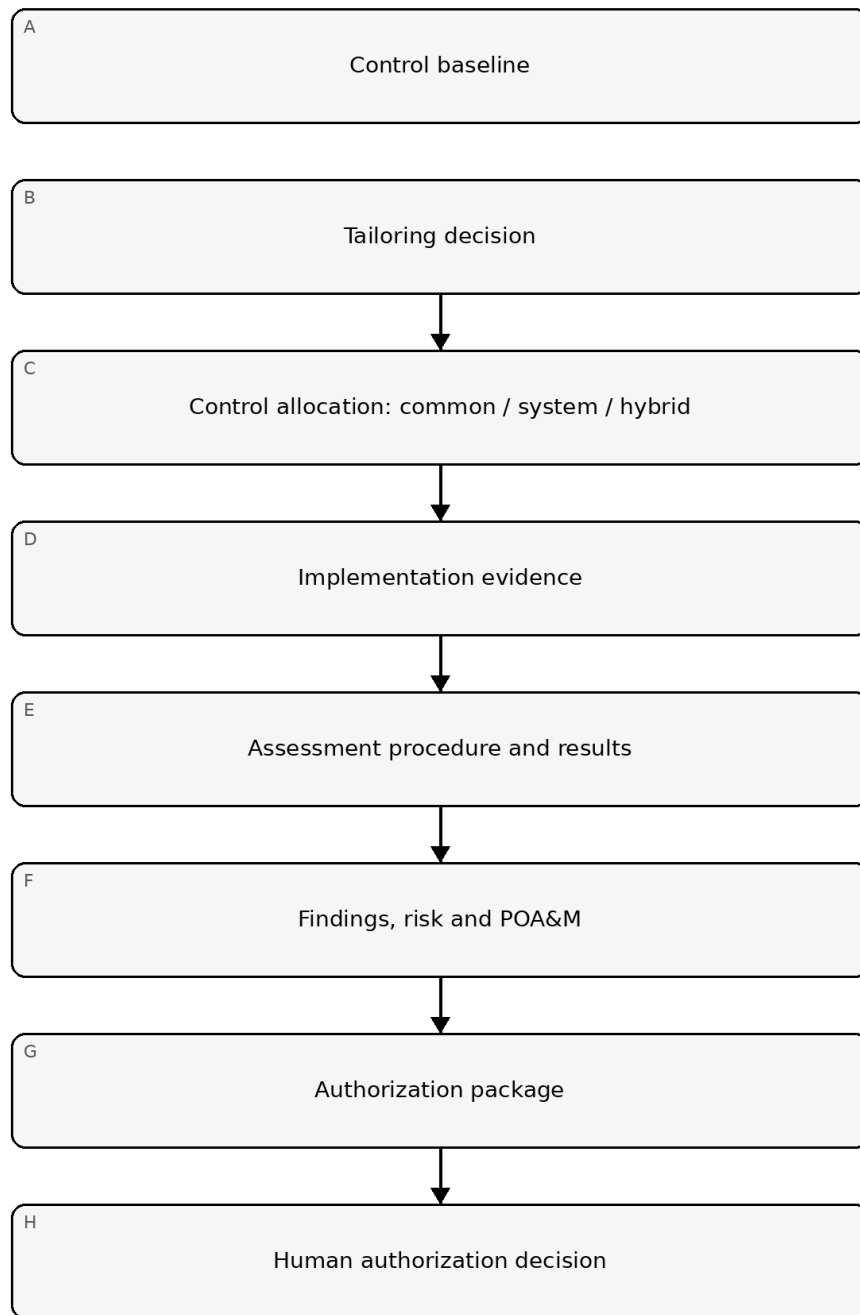


Figure 2. RMF implementation memory graphic

Accessible explanation: Evidence must connect baseline selection, tailoring, allocation, implementation, assessment, findings, remediation and the final accountable authorization decision. No checklist or automated workflow replaces that chain.

Planning and machine-readable evidence chain

Manual 10 memory graphic 3

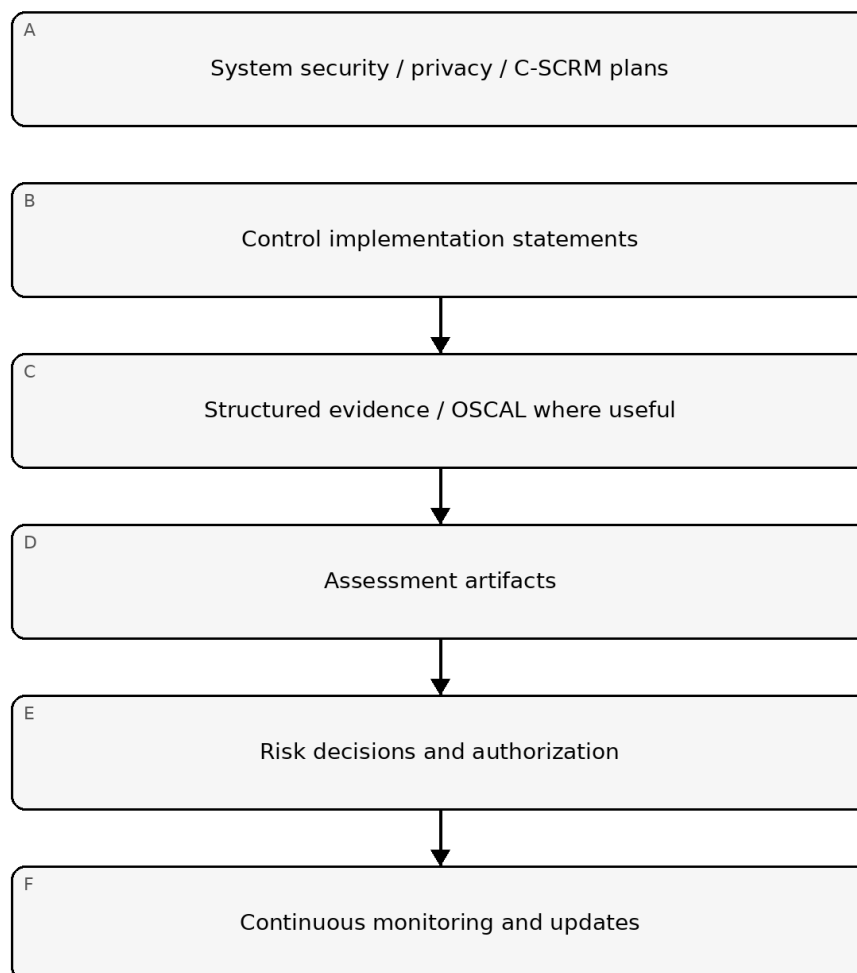


Figure 3. RMF implementation memory graphic

Accessible explanation: System plans and implementation statements should remain connected to assessment evidence, risk decisions, authorization, and monitoring. Machine-readable formats can improve traceability but do not create assurance by themselves.

Control boundary

The manual is risk-based, tailorable, and evidence-based. It must not present SP 800-53 controls as universally mandatory outside their applicable governance context, must not treat the baseline as an untailored checklist, and must not imply that passing repository QA or an automated control test constitutes authorization, certification, or risk acceptance.

Controlled 32-chapter manual

Chapter 01 — RMF purpose and decision architecture

Use RMF as a risk-management operating cycle that connects mission objectives, system context, security and privacy risk, control implementation, assessment evidence, authorization decisions, and continuous monitoring. Avoid treating the framework as a one-time documentation exercise.

Define accountable roles, system boundaries, decision authorities, escalation routes, evidence expectations, and how organization-level and system-level risk decisions interact.

Chapter 02 — PREPARE at the organization level

Establish organization-wide risk assumptions, governance, risk tolerance, common-control strategy, supply-chain expectations, enterprise architecture, shared services, assessment strategy, and monitoring strategy before individual systems are evaluated.

Evidence should show ownership, approved risk criteria, dependency assumptions, common-control providers, reusable evidence, and unresolved enterprise-level risks.

Chapter 03 — PREPARE at the system level

Define the system mission, business owner, system owner, authorization boundary, operating environment, users, data, interfaces, dependencies, suppliers, inherited services, and expected lifecycle.

Document assumptions and unknowns explicitly. Boundary uncertainty, unclear ownership, or missing dependency information must remain visible as risk rather than being normalized away.

Chapter 04 — Stakeholder and role accountability

Identify the authorizing official, risk executive function, system owner, information owner, control providers, assessors, security/privacy officers, architects, engineers, operations teams, legal/privacy participants, supply-chain stakeholders, and business representatives needed for the system.

Segregate implementation, assessment, and authorization responsibilities sufficiently to preserve credible challenge and decision accountability.

Chapter 05 — Information and system characterization

Characterize information types, processing purpose, users, technologies, locations, interfaces, data flows, external connections, cloud or shared-service dependencies, operational technology where relevant, and supply-chain relationships.

The characterization should support both security and privacy analysis and be maintained as the system changes.

Chapter 06 — CATEGORIZE security impact

Categorize the system using applicable impact-analysis methods and organizational policy. Record the rationale for confidentiality, integrity, and availability impact determinations, including mission consequences and dependencies.

The category is a decision input, not a substitute for threat, privacy, or business-risk analysis. Tailoring and risk decisions must remain traceable to context.

Chapter 07 — Privacy and additional impact considerations

Integrate privacy risk, legal obligations, data sensitivity, mission harms, safety considerations, contractual requirements, supply-chain exposure, and other context that may require controls or protections beyond the initial security category.

Document where separate privacy analysis, risk assessment, or specialist review affects the control baseline or authorization package.

Chapter 08 — PREPARE/CATEGORIZE fail-closed gate

Do not proceed as if the system is ready for control selection when the authorization boundary is unresolved, accountable ownership is missing, impact determinations are unsupported, critical dependencies are unknown, or organization-level assumptions conflict with system reality.

Automated checks may verify required records and relationships, but competent human judgment is required for categorization, scope, and accountability decisions.

Chapter 09 — SELECT the initial control baseline

Choose an appropriate initial control baseline using applicable organizational policy and NIST guidance. Record the baseline source, system impact context, assumptions, inherited controls, common controls, overlays, and other requirements that influence the starting set.

The initial baseline is not the final control set. It is the structured starting point for tailoring and risk-based refinement.

Chapter 10 — Tailoring and scoping decisions

Tailor controls transparently based on applicability, technology, mission, risk, environment, compensating safeguards, legal or contractual obligations, and organizational risk tolerance.

Every substantive tailoring decision should record rationale, authority, affected controls, assumptions, residual risk, dependencies, and review conditions. Tailoring must not become undocumented control deletion.

Chapter 11 — Common, system-specific, and hybrid controls

Classify controls according to where responsibility and implementation reside. Identify common-control providers, inherited portions, system-specific responsibilities, hybrid boundaries, and evidence owners.

Inheritance claims must identify the actual provider, implementation scope, evidence source, applicability, status, and any system-specific parameters or residual responsibilities.

Chapter 12 — Control parameterization and implementation statements

Translate selected controls into system-specific implementation statements, parameters, roles, technologies, procedures, and evidence expectations. Avoid generic restatement of control objectives without explaining how the system satisfies them.

Implementation statements should be testable, current, version-controlled, and traceable to architectures, configurations, procedures, logs, tickets, contracts, or other supporting evidence.

Chapter 13 — System security, privacy, and C-SCRM planning

Maintain planning documentation that explains system context, selected controls, implementation approach, privacy considerations, supply-chain dependencies, risk assumptions, responsibilities, and evidence sources.

Use current NIST planning guidance to structure living records rather than static documents produced only for authorization events.

Chapter 14 — IMPLEMENT controls in the operational environment

Implement selected controls in technology, process, people, facilities, contracts, and supplier relationships as applicable. Configuration, procedures, access boundaries, monitoring, training, recovery, and evidence collection should reflect the approved control design.

Implementation completion should be based on evidence, not on task status alone.

Chapter 15 — Implementation evidence and provenance

For each material control implementation, preserve evidence sufficient to show what was implemented, where, by whom, when, under what configuration or version, and with what limitations.

Evidence should be relevant, current, attributable, tamper-resistant where appropriate, and linked to the exact system scope. Machine-generated evidence requires provenance and human interpretation where judgment is involved.

Chapter 16 — SELECT/IMPLEMENT fail-closed gate

Do not treat the control set as implementation-ready when tailoring rationale is missing, inherited-control responsibility is ambiguous, implementation statements are not testable, critical parameters are undefined, or evidence cannot be traced to the actual system.

Automation may assist control mapping and evidence collection, but it cannot establish applicability, effective implementation, or acceptable residual risk by itself.

Chapter 17 — Assessment planning

Define assessment scope, objectives, selected controls, procedures, evidence sources, independence expectations, sampling, test environments, stakeholders, schedules, and limitations before fieldwork begins.

The plan should distinguish design, implementation, and operating-effectiveness questions and identify where inherited or common controls require separate evidence.

Chapter 18 — Evidence sufficiency and quality

Evaluate evidence for relevance, reliability, currency, completeness, scope, provenance, and applicability to the control implementation being assessed. A valid artifact may still be insufficient if it covers the wrong environment, period, service, or responsibility boundary.

Document assumptions, unavailable evidence, contradictory evidence, and uncertainty rather than concealing them behind pass/fail labels.

Chapter 19 — Assessment procedures and testing

Use appropriate examination, interview, and test procedures to determine whether controls are implemented correctly, operating as intended, and producing the desired outcome. Tailor procedures to technology, risk, system context, and available evidence.

Automated testing can improve coverage and repeatability, but assessor judgment remains necessary for interpretation, scope, limitations, and significance.

Chapter 20 — Findings, weaknesses, and severity

Record findings with affected controls, system scope, evidence, condition, expected state, risk consequence, root cause where known, severity rationale, owner, remediation path, and validation requirements.

Do not reduce findings to checklist exceptions without explaining material risk or implementation impact.

Chapter 21 — Assessment report and risk package

Prepare an assessment package that distinguishes tested scope, procedures performed, evidence reviewed, findings, limitations, inherited-control dependencies, unresolved questions, and assessor conclusions.

The package should support risk decisions without overstating assurance beyond the evidence collected.

Chapter 22 — Authorization package

Assemble the information required for an accountable authorization decision, including system plans, control implementation evidence, assessment results, risk assessments, POA&M items, exceptions, common-control dependencies, residual-risk statements, and relevant operational constraints.

The package should expose material uncertainty and open risk rather than optimize for a clean appearance.

Chapter 23 — Authorization decision and conditions

The authorizing official or equivalent accountable authority decides whether residual risk is acceptable for the defined mission, scope, environment, and period. Decisions may authorize, authorize with conditions, require remediation, restrict operation, defer, or deny authorization.

Record decision authority, date, scope, evidence considered, material risk, conditions, expiration or review triggers, and required follow-up.

Chapter 24 — ASSESS/AUTHORIZE fail-closed gate

Do not treat a system as ready for authorization when assessment scope is materially incomplete, significant findings are unsupported or unresolved, evidence quality is inadequate, authorization responsibility is unclear, or residual risk is hidden from the decision-maker.

Automation may support assessment and package assembly, but no automated workflow may substitute for competent assessment judgment or the accountable human authorization decision.

Chapter 25 — Continuous monitoring strategy

Define which controls, risks, configurations, vulnerabilities, events, dependencies, suppliers, evidence sources, and system changes require ongoing monitoring. Establish frequency, triggers, owners, evidence retention, reporting, thresholds, and escalation.

Monitoring should prioritize risk and change, not merely collect recurring metrics.

Chapter 26 — Change impact and configuration control

Evaluate material system, architecture, software, data, identity, supplier, cloud, interface, mission, and control changes for impact on selected controls, implementation evidence, assessment conclusions, and authorization conditions.

Changes that invalidate evidence or risk assumptions must reopen the affected review rather than inherit stale conclusions.

Chapter 27 — POA&M and remediation governance

Manage Plans of Action and Milestones as accountable risk-treatment records. Each item should identify the weakness, affected system or control, risk significance, owner, remediation action, milestones, dates, interim controls, dependencies, evidence requirements, and escalation path.

Repeated date extensions without updated risk analysis and approval should not be treated as effective remediation.

Chapter 28 — Ongoing assessment and evidence refresh

Refresh assessment evidence according to risk, control volatility, monitoring results, incidents, changes, expiration, and authorization conditions. Reassess controls when evidence becomes stale, scope changes, implementation differs from the approved state, or new risk information emerges.

Continuous monitoring does not eliminate the need for targeted human assessment and independent challenge.

Chapter 29 — Common-control and inherited-risk monitoring

Track common-control providers and inherited controls throughout the authorization period. Monitor provider changes, outages, findings, scope changes, assessment results, and evidence currency that may alter relying systems' risk posture.

A system must not continue to credit inherited protection when the provider evidence no longer supports that claim.

Chapter 30 — OSCAL and machine-readable evidence

Use OSCAL or other machine-readable formats where appropriate to improve traceability, exchange, validation, automation, and provenance across catalogs, profiles, implementation plans, assessment plans/results, and related evidence.

Machine-readable records must preserve source identity, version, scope, authorship, timestamps, limitations, and human decision boundaries. Automation increases consistency but does not create authorization authority.

Chapter 31 — Continuous authorization support and risk decisions

Use monitoring and updated evidence to support ongoing risk decisions, including continued operation, conditions, remediation, restrictions, reassessment, or reauthorization when required by policy or material change.

Continuous authorization should mean continuous availability of decision-quality evidence and governance—not automatic approval by tooling. The controlled assurance boundary is no automatic authorization: tooling may support evidence and workflow, but authorization remains an accountable human risk decision.

Chapter 32 — Manual release and assurance boundary

Manual 10 closes only when authoritative-source verification, the controlled 32-chapter English master, technical/editorial/control-mapping review, es-419 and pt-BR localization with human semantic review, graphics/accessibility review, DOCX/PDF publication QA, repository/workflow security review, manifest/checksums/provenance, exact-head reconciliation, and Final Human Release Approval are complete for the same exact candidate.

Completion establishes a reviewed implementation baseline. It does not authorize any real system, certify compliance, eliminate residual risk, or replace the accountable authorizing official, competent assessor, legal counsel, privacy professionals, or other required specialists.